RELATÓRIO DE ENTREGA — Rede Krill Agendamento

Data: 2026-11-03 · **Ambiente:** máquina local Windows (JDK 21, Node 26, sem Docker)

Este documento responde à pergunta central da entrega com quatro categorias explícitas: o que foi **CONCLUÍDO E VALIDADO** (com evidência), o que foi **IMPLEMENTADO, MAS NÃO VALIDADO**, o que ficou **PENDENTE POR LIMITAÇÃO EXTERNA** e o que **NÃO FOI IMPLEMENTADO** (com justificativa). Nenhuma afirmação foi marcada como validada sem execução real.

---

1. CONCLUÍDO E VALIDADO

1.1 Backend

Item	Evidência
Spring Boot **4.1.2**, Java 21, starters corretos (webmvc/security/data-jpa/validation/actuator/mail/thymeleaf/flyway)	`backend/pom.xml` ; build `mvnw clean verify` verde
214 testes (unitários + integração com PostgreSQL embarcado + ArchUnit), 0 falhas/0 erros	saída do `mvnw clean verify` desta data
Cobertura JaCoCo **87,61% linhas / 71,43% branches / 86,84% instruções**	`backend/target/site/jacoco/jacoco.csv` após o verify
Arquitetura hexagonal protegida por **ArchUnit** (4 regras)	`ArchitectureTest` : 4 testes passando
Sessão: JWT em cookie HttpOnly (15 min), refresh opaco rotativo com hash SHA-256 em `auth_session` , revogação em logout/desativação	integração `SchedulingApiIntegrationTest` (10 testes); código em `infrastructure/security`
CSRF double-submit (`XSRF-TOKEN` / `X-XSRF-TOKEN`) com Bearer isento (Swagger/testes) e endpoint `GET /api/auth/csrf`	integração + controller
Rate limiting de login (5/conta e 20/IP por 15 min, bloqueio 5 min) com 429 e auditoria	`LoginRateLimiter` + testes unitários
Seed admin seguro: exigência de `SEED_ADMIN_PASSWORD` , rejeição de senhas conhecidas, idempotently só cria se e-mail inexistente, falha em prod sem senha	`DataInitializer` + testes
Troca de senha obrigatória no primeiro acesso (`PasswordChangeRequiredFilter` + flag `must_change_password`)	integração + E2E frontend

Item	Evidência
Duplicidade de `orderId` → **409**; `@Version` em usuário/agendamento (conflito de edição)	`CreateAppointmentUseCaseTest` etc.
`UpdateUserRequest.active` → `Boolean @NotNull`; desativação revoga sessões e reset força troca	`UserController` + testes
Auditoria completa: ator (ou `ANONYMOUS` explícito), login inválido/bloqueado, 401/403, logout, senha	`AuditService` + `GlobalExceptionHandlerTest` (13 testes) + integração
CRUD horários (2 h exatas, 4/dia, sem sobreposição) e paletização (2 obrigatórios com multiplicadores fixos; extras código `OUTRO`, multiplicador 1–100, nome único), exclusões bloqueadas quando em uso (409)	use cases + testes + integração
Limites fixos 480/dia · 120/faixa, multiplicador só na faixa; avisos sem bloqueio; `capacity_settings` removida na V5 com justificativa no ADR-004	`CapacityPolicy` + migrações
Relatório paginado no banco com totais agregados (contagem + somas de pallets declarados/efetivos)	`GetAppointmentReportUseCase` + testes (5) + integração
E-mail via **outbox transacional** (`email_outbox` V6/V7) com retry/backoff e métricas Micrometer; resposta comunica `emailQueued`, nunca "enviado"	`EmailOutboxProcessor` + testes/mocks
Validação de configuração de produção no boot (JWT fraco/conhecido, cookies sem Secure, seed sem senha → boot falha)	`ProductionConfigurationValidator`
Correlation ID (`X-Correlation-ID`, MDC no log, retorno no header), logs ECS em prod, `/actuator/health` + `/actuator/prometheus`	`CorrelationIdFilter` + application.yml
Flyway V1..V7 com `clean-disabled=true` em prod	`backend/src/main/resources/db/migration/`

1.2 Frontend

Item	Evidência
Sem `localStorage` de token; sessão via cookies com `GET /me`, CSRF garantido e **refresh silencioso único** com retry	`src/services/api.js`, `src/stores/auth.js` + testes
20 testes Vitest (api client/CSRF/refresh, store auth/safeRedirect, projeção de capacidade) — 0 falhas	`npm test` desta data
ESLint (flat config) sem erros/warnings e Prettier aplicado	`npm run lint`, `npm run format`
`vue-tsc --noEmit` sem erros	`npm run typecheck`
Build Vite **8.3.5** com code splitting por rota (chunks por view)	`npm run build` (saída lista `UserView-*.js`, `TimeSlotsView-*.js`, …)
3 testes E2E Playwright (redirect seguro pós-login rejeitando `//` e URLs absolutas; bloqueio por troca obrigatória; mensagem de credenciais inválidas) — passando	`npm run test:e2e` desta data
Ocupação projetada em tempo real no modal de agendamento com baseline de edição e aviso (sem bloqueio)	`AppointmentsView.vue` + `capacity.test.js` (6 testes)

Item	Evidência
Telas novas de CRUD: `TimeSlotsView.vue`, `PalletizationTypesView.vue`, `ChangePasswordView.vue`; navegação e guards atualizados	arquivos + router com lazy loading
Correção de UX/acessibilidade dos campos de senha (inputId) e banner de confirmação pós-troca	`LoginView.vue`, `ChangePasswordView.vue`
Vitest/Vite/Vitest+Playwright/ESLint incorporados; `npm audit` = **0 vulnerabilidades** após overrides `glob ^14.0.2` / `minimatch ^11.0.1`	`npm audit` desta data

1.3 Infra/CI/Docs

Item	Evidência
`docker-compose.yml` com segredos obrigatórios `${VAR:?}`, perfil `dev` (MailHog), healthchecks Postgres/backend/frontend	arquivo + parse YAML válido
`.env.example` sem segredos reais; `.env` no `.gitignore`	arquivo
`nginx.conf` com CSP/headers, proxy `/api`, swagger e cache imutável; Dockerfile frontend Node 24	arquivos
CI GitHub Actions: backend (verify+JaCoCo), frontend (lint/format/typecheck/test+coverage/build/e2e), infra (compose config), dependency-check semanal/manual; Dependabot semanal	`.github/workflows/ci.yml`, `.github/dependabot.yml`
OWASP Dependency-Check executado manualmente (plugin 12.2.2, perfil `security` no pom com `failBuildOnCVSS=7`) — **0 vulnerabilidades em 86 dependências**	`backend/target/dependency-check/dependency-check-report.json`
README reescrito com stack/segurança/endpoints/execução/testes/limitações	`README.md`
ADRs 001–010 em `docs/arquitetura/` (007–010 adicionadas em 03/11)	arquivos
`SECURITY_REPORT.md` com evidências separadas de limitações	arquivo
Runbook operacional em `docs/operacao/RUNBOOK.md`	arquivo
PDF de entrega e roteiro de vídeo em `docs/entrega/`	`RELATORIO_ENTREGA.pdf`, `ROTEIRO_VIDEO.md`

2. IMPLEMENTADO, MAS NÃO VALIDADO

Estes itens têm código/`config` no repositório e testes de lógica, mas **sem execução real do ambiente completo**:

- **Dashboard/métricas com Prometheus externo**: endpoints expostos; nenhum Prometheus configurado para consumir (sem infra nesta máquina).
- **MailHog/UI**: perfil `dev` configurado; interface nunca aberta.

- **Code splitting com cache de navegador**: build gera chunks (verificado no output), mas comportamento em navegação real com cache/HTTP2 do nginx não foi exercitado.
- **Swagger UI em produção**: rota gated por perfil; não aberta em navegador contra prod.
- **Refresh rotativo sob concorrência de múltiplas abas**: coberto por teste de um fluxo linear; cenário com duas abas simultâneas não reproduzido manualmente.

3. PENDENTE POR LIMITAÇÃO EXTERNA

Item	Limitação	Alternativa adotada
Execução da stack Docker/Compose (subir 3 containers, healthcheck real)	Docker indisponível nesta máquina	Validado estaticamente (YAML, variáveis, ordem, healthchecks declarados); passos no runbook
SMTP real (envio e ida/volta com cliente de e-mail)	Não há servidor SMTP acessível (MailHog exige Docker)	Outbox testada com mocks; métricas e estados implementados
E2E com backend real (frontend + API + banco no mesmo ambiente)	Depende da stack Docker	E2E de frontend com API mockada (3 testes); integração backend cobre API
NVD API key para Dependency-Check completo	Chave não fornecida (não inventada)	Rodou sem key: NVD baixou 911 registros; 0 achados; CI usa chave opcional
Validação do pipeline GitHub Actions	Não há push remoto nesta sessão; primeiro push validará	YAML revisado; jobs isolados

4. NÃO IMPLEMENTADO, COM JUSTIFICATIVA

1. **Rate limiting distribuído (Redis/banco)** — o mecanismo atual funciona por instância; multi-instância não faz parte do escopo de deploy avaliado. Recomendado antes de escalar horizontalmente (ADR-010 e `SECURITY_REPORT.md` §11 registram a limitação).
2. **2FA/MFA e recuperação por e-mail** — fora do escopo do desafio; exigiria backend de envio confiável (SMTP) e decisões de produto não levantadas. A troca obrigatória + política de senha cobre parte do risco.
3. **UI para gestão da outbox de e-mail** — visível apenas via métricas/banco; prioridade menor que telas operacionais. Todos os estados estão no banco e na métrica Prometheus.
4. **Compatibilidade com empresa de navegadores antigos (IE/legados)** — build moderno (esbuild/rolldown) sem polyfills deliberadamente; público interno.
5. **Clean de histórico do Git para segredos antigos** — o histórico remoto é público e pertence ao repositório do usuário; limpeza de histórico (`git filter-repo`) exige decisão e execução pelo dono do repo (docs a indicam; não executada por isso).

5. Estado do repositório

- Branch: `main` · HEAD: `a9bbc7b` (03/11/2026 00:49 — ainda em `origin/main` está `06cee93`); **nenhum commit/push executado** nesta sessão — todas as alterações estão no workspace para revisão e commit do usuário.
- Recomendação de sequência: revisar diff → commit único ou em blocos (backend/frontend/docs) → push → acompanhar a primeira execução do CI.

6. Como reproduzir a validação

```
# Backend
cd backend ; .\mvnw.cmd clean verify          # 214 testes + JaCoCo
.\mvnw.cmd -B -q -Psecurity -DskipTests org.owasp:dependency-check-maven:check

# Frontend
cd frontend ; npm ci
npm run lint ; npm run format:check ; npm run typecheck ; npm test ; npm run build
npm run test:e2e                              # Playwright (instalado nesta máquina)
npm audit                                     # 0 vulnerabilidades
```